

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)

☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

	Yes	No	Best practice
.	☐	☒	Only authorized users have access to customers' credit card information.
.	☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
.	☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
.	☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

	Yes	No	Best practice
.	☐	☒	E.U. customers' data is kept private/secured.

☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☒	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

Controls Assessment Checklist-

There is no separation of duties, so all employees currently have access to all data. This should be remedied so that they only have access to the items pertinent to their role. There is also no encryption feature protecting sensitive information and no disaster recovery plan available should a threat actor access this information. There is also not currently a back-up of data available in case of a breach or system outage which could harm the ability for the business to continue day to day operations. Lastly, while legacy systems are being monitored, there is no system in place for regular maintenance or intervention plan available.

Physical Location appears to be well equipped with CCTV, Locks, and Fire detection systems.

Payment Card Industry Data Security Standard (PCI DSS)-

All employees currently have access to all customer data as there is no encryption or separation of duties currently in place. There are password policies, however, they are minimal and there is no password management system in place.

General Data Protection Regulation (GDPR)-

There is a plan in place to notify E.U. customers of a breach, as well as policies for document maintenance and storage, however as all employees currently have access to this unencrypted information it could be debated that there is already a breach of these policies in regards to customer privacy.

Systems and Organization-

The IT department has verified the availability and integrity of data. However as previously mentioned, there is no separation of duties and no access policy in place to prohibit employees from accessing PII/SPII. Also as there is not an intrusion detection system in place, this data could be easily retrieved by bad actors.